



DEPARTMENT CIRCULAR NO. **HRA-001**
Series of 2026

JAN 08 2026

**SUBJECT : ACCREDITATION OF DICT TRUSTED ASSESSMENT PROVIDERS
(DTAPs)**

WHEREAS, Article II, Section 24 of the 1987 Constitution of the Republic of the Philippines provides that "The State recognizes the vital role of communication and information in nation-building";

WHEREAS, Section 2(m) of Republic Act (RA) No. 10844, otherwise known as the "Department of Information and Communications Technology Act of 2015," mandates the State "to ensure the security of critical ICT infrastructures including information assets of the government, individuals and businesses";

WHEREAS, Section 6 of RA No. 10844 empowers the Department of Information and Communications Technology (DICT) to "formulate, recommend and implement national policies, plans, programs, and guidelines that will promote the development and use of ICT with due consideration to the advantages of convergence and emerging technologies" and to "assist and provide technical expertise to government agencies in the development of guidelines in the enforcement and administration of laws, standards, rules, and regulations governing ICT";

WHEREAS, Executive Order No. 58, series of 2024, adopted the National Cybersecurity Plan (NCSP) 2023-2028 as the comprehensive, whole-of-nation roadmap of the Philippine government that outlines the national vision, policy direction, and framework for cybersecurity, as issued by the DICT;

WHEREAS, Outcome 3.4 of the NCSP 2023-2028 underscores the necessity for advanced technical knowledge, substantial experience, and ethical practice among Vulnerability Assessment and Penetration Testing (VAPT) and Information Security Management System (ISMS) service providers;

WHEREAS, the DICT's Cybersecurity Bureau presently administers a program for the Recognition of Cybersecurity Assessment Providers, and there is currently a compelling need to institute a formal accreditation framework for VAPT and ISMS service providers to guarantee the quality, reliability, and ethical competency of services rendered;

WHEREAS, to facilitate an orderly transition to the accreditation of DICT Trusted Assessment Providers (DTAPs) framework, it is necessary to officially discontinue the

antecedent recognition program for cybersecurity assessment providers and to implement a transition period of ninety (90) days from the effectivity of this Circular, during which service providers recognized under the previous program may continue their engagements, provided they secure accreditation under this new framework to provide services thereafter, and to cease the issuance of new recognitions under the former program during this transition;

NOW, THEREFORE, pursuant to the foregoing considerations and the provisions of existing laws, rules, and regulations, the following guidelines on the accreditation of DTAPs are hereby issued:

Section 1. Purpose. — This Circular establishes the official framework and governing procedures for the formal accreditation of service providers offering VAPT and ISMS assessments. The primary objective is to ensure that government agencies and entities managing Critical Information Infrastructures (CIIs) are serviced by competent, reliable, ethical, and high-caliber firms and cybersecurity professionals.

Section 2. Definition of Terms. — For the purposes of this Circular, the following terms are hereby defined:

- a. **Critical Information Infrastructure (CII)** refers to the information process and Information Communications Technology, which form part of the operation of the Critical Infrastructures (CI) pursuant to NCSP 2023-2028.
- b. **Critical Infrastructure (CI)** refers to a set of systems and assets that are essential to a nation such that any disruption of their service can have a serious impact on national security, economy, social well-being, and citizen safety.
- c. **Cybersecurity Bureau** refers to the DICT office responsible for information security and incident response, which shall oversee the DTAP accreditation process.
- d. **DICT Trusted Assessment Provider (DTAP)** refers to entities accredited by DICT to deliver professional VAPT and ISMS assessment services.
- e. **Information Security Management System (ISMS)** refers to a comprehensive and systematic approach to managing an organization's sensitive information to ensure its security. An ISMS encompasses people, processes, and technology, all governed by a robust risk management process.
- f. **Vulnerability Assessment and Penetration Testing (VAPT)** refers to a security auditing methodology involving the systematic identification, quantification, and exploitation of security vulnerabilities within a computer system, network, or application to evaluate its security posture.

Section 3. Coverage. — This Circular shall apply to all national government agencies and instrumentalities, including, but not limited to, CIIs, Government-Owned and Controlled

Corporations (GOCCs) and their subsidiaries, Government Financial Institutions (GFIs), Local Government Units (LGUs), and State Universities and Colleges (SUCs).

All such covered entities shall engage only with DICT-accredited Trusted Assessment Providers for the conduct of vulnerability assessments and penetration testing of their ICT systems, networks, and applications.

This Circular likewise applies to any person or entity providing cybersecurity assessment services to the covered entities.

Section 4. Accreditation Requirements. — An applicant seeking accreditation as a DTAP shall satisfy the following:

- a. **Legal and Organizational Qualifications** – Applicants shall be juridical entities duly registered and in good standing under Philippine laws, with primary business operations in information and communications technology (ICT), cybersecurity, or related fields. Furthermore, the entity shall be at least sixty percent (60%) owned and controlled by Filipino citizens, allowing for a maximum of forty percent (40%) foreign ownership or participation.
- b. **Operational and Financial Health Stability** – Entities applying for accreditation shall demonstrate sufficient operational capacity and financial health to ensure the consistent delivery of high-quality cybersecurity assessment services. To establish this, the entity shall maintain a positive net worth, as reflected in its latest audited financial statements.
- c. **Service Delivery Team** – The applicant shall have on its roster of permanent employees or through a consortium the necessary cybersecurity professionals or its respective equivalent positions, possessing the requisite functions:
 - i. **Project Manager / Lead Consultant** who shall:
 1. Formulate and define the scope and objectives of the assessment engagement;
 2. Effectively allocate and manage personnel and resources;
 3. Supervise project timelines and deliverables, and resolve emerging technical or operational issues;
 4. Serve as the principal liaison between the client and the service provider, ensuring effective communication with stakeholders and explaining the limitations inherent in VAPT methodologies that may affect the reliability or completeness of findings;
 5. Oversee the technical and qualitative review of outputs to ensure accuracy, integrity, and relevance of findings; and
 6. Submit final reports and documentation to the client.
 - ii. **VAPT Specialist / Engineer / Analyst / Tester** who shall:

1. Conduct vulnerability scanning and penetration testing activities across networks, applications, and systems;
 2. Perform threat modeling and assess architectural security configurations;
 3. Interpret and correlate technical results to identify and prioritize threats;
 4. Formulate technically feasible and risk-informed remediation recommendations; and
 5. Provide post-assessment assistance in implementing remediation actions and verifying effectiveness, where applicable.
- iii. **ISMS Consultant** who shall:
1. Conduct assessments pursuant to the ISO/IEC 27001 standard or equivalent ISMS framework;
 2. Review and evaluate the sufficiency of information security policies, controls, and operating procedures;
 3. Analyze the effectiveness of the ISMS implementation and identify associated risks;
 4. Propose actionable, standards-based improvements for risk mitigation and compliance;
 5. Guide the implementation of necessary controls, where applicable; and
 6. Perform follow-up assessments to confirm adequacy of corrective actions and conformance with standards.
- iv. **Quality Assurance Personnel** who shall:
1. Validate compliance with all applicable standards, methodologies, and regulations;
 2. Enforce adherence to formally adopted assessment protocols;
 3. Monitor and resolve service delivery issues or deviations from agreed methodologies; and
 4. Evaluate post-remediation risk posture to determine adequacy of mitigation measures.
- d. **Knowledge and Professional Competency** – All applicant's personnel performing services under the scope of VAPT and/or ISMS assessments shall possess, at all times, valid and relevant professional certifications as proof of their technical competency, readiness, and adherence to the highest standards of practice in cybersecurity. A list of prescribed certifications for personnel performing VAPT and ISMS assessments is attached as Annex A.
- e. **Service Quality and Assessment Methodologies** – Applicants shall strictly observe internationally recognized methodologies and best practices in the performance of VAPT and ISMS assessments to ensure the consistency, integrity, and effectiveness of assessment outputs.

- i. **VAPT Assessment Services** – Applicants shall adopt a structured methodology that includes, at a minimum, the following phases:
 - 1. Scoping of the engagement, including objective setting and agreement on rules of engagement;
 - 2. Information Gathering through reconnaissance and enumeration techniques;
 - 3. Vulnerability Identification and Enumeration based on collected data;
 - 4. Exploitation of identified vulnerabilities under controlled conditions;
 - 5. Maintaining Access for the purposes of privilege escalation or lateral movement, if applicable and authorized;
 - 6. Clean-up activities to remove any test artifacts or temporary access mechanisms, if applicable; and
 - 7. Reporting and Documentation of all findings, conclusions, and recommendations in a clear and technically comprehensive manner.
 - ii. **ISMS Assessment Services** – Applicants shall adhere to a documented and repeatable ISMS assessment methodology comprising, at a minimum, the following activities:
 - 1. Scoping of assessment based on organizational context and ISMS boundaries;
 - 2. Information Gathering, including collection of applicable policies, procedures, and operational evidence;
 - 3. Controls Assessment against the selected ISMS standard or framework;
 - 4. Gap Analysis to determine deviations from standard requirements;
 - 5. Clean-up activities to finalize audit trails or address residual data, if applicable; and
 - 6. Reporting and Documentation of assessment results, risk observations, and recommended corrective actions.
- f. **Entity-level certification and standards** - Entities seeking DTAP accreditation for VAPT and/or ISMS services are required to have at least one (1) of the following entity- or organization-level certifications, or other equivalent entity-level certifications:
- i. For VAPT Assessment Services:
 - 1. ISO 9001: Quality Management Systems
 - 2. ISO/IEC 27001: Information Security Management Systems
 - 3. SOC 2 (Service Organization Control 2) Certification
 - 4. CREST Accredited Company
 - ii. For ISMS Assessment Services:
 - 1. ISO 9001: Quality Management Systems
 - 2. ISO/IEC 27001: Information Security Management Systems (For ISMS Assessment Services only)

- g. **Adherence to Recognized Frameworks** – In the evaluation of applications, favorable consideration shall be given to applicants that demonstrate alignment of their internal cybersecurity policies and practices with established international frameworks. Such frameworks include, but are not limited to, the following:
 - i. National Institute for Science and Technology (NIST) Cybersecurity Framework (CSF) 2.0;
 - ii. Center for Internet Security (CIS) Controls v8.0 ; and
 - iii. COBIT (Control Objectives for Information and Related Technologies).
- h. **Other requirements** – The Cybersecurity Bureau may mandate other requirements as deemed necessary to elucidate the applicants' additional accreditation requirements, provided that the applications are given reasonable time to comply.

Section 5. Documentary Requirements. – Applicants shall submit the following complete documentary requirements through the official online portal designated by the Cybersecurity Bureau:

- a. **Foundational Documents**
 - i. A duly accomplished and signed Application Form addressed to the Director of the Cybersecurity Bureau.
- b. **Company Profile**
 - i. A detailed list of the applicant's service portfolio; and
 - ii. The URL of the applicant's valid and active company website.
- c. **Evidence of relevant entity-level certifications as required under this Circular**
- d. **Permits and Licenses**
 - i. A certified true copy of the Certificate of Registration from the Securities and Exchange Commission (SEC);
 - ii. A certified true copy of a valid Business Permit for the current year of application;
 - iii. A copy of the Bureau of Internal Revenue (BIR) Registration; and
 - iv. A valid PhilGEPS Red Certificate of Registration and Membership.
- e. **Performance and Track Record**
 - i. Performance evaluations from client engagements conducted within the last three (3) years preceding the application. The DICT reserves the right to contact the clients listed therein for the purpose of validating the applicant's quality of service and professionalism.

f. **Personnel Clearances and Certifications**

- i. NBI Clearances for all key personnel involved in the assessment services;
- ii. Certifications of Employment for the cybersecurity staff; and
- iii. Copies of valid and up-to-date cybersecurity-related professional certifications; and
- iv. Curriculum Vitae of all key personnel involved in the assessment services.

g. **Notarized Attestation**

A notarized Attestation regarding the firm's Human Resource practices, which shall affirm and declare that:

- i. The firm deploys only competent, ethical, and trustworthy personnel in the conduct of all assessment services; and
- ii. The firm acknowledges its full accountability for any unprofessional, unethical, or unlawful acts committed by its personnel, and that failure to address such conduct shall be a ground for suspension or revocation.

Section 6. Accreditation Process. — The following procedures shall govern the accreditation of DTAPs:

- a. **Application** – An applicant shall submit a completed application form to the Cybersecurity Bureau, including the following supporting documents:
 - i. Corporate registration papers;
 - ii. Business permits;
 - iii. Detailed company profile;
 - iv. Curriculum Vitae of all key personnel involved in the assessment services (with certification copies);
 - v. Description of assessment methodology and tools; and
 - vi. At least two (2) reference letters or certificates of performance from recent cybersecurity assessment engagements.
- b. **Evaluation** – The Cybersecurity Bureau shall evaluate the application for completeness and compliance with the requirements of Section 4. The Bureau shall render a decision within seven (7) working days for complex transactions as prescribed by the Republic Act No. 11032, otherwise known as the “Ease of Doing Business Act and Efficient Government Service Delivery Act of 2018.”
- c. **Issuance of Accreditation** – Upon approval, the DICT Secretary or duly authorized official shall issue **Accreditation Certificate** to the applicant, indicating the effective date of accreditation.
- d. **Validity and Renewal** – Accreditation shall be valid for one (1) year from the issuance of the Certificate of Accreditation. However, the one (1) - year validity period is contingent on a successful optional annual surveillance audit. The DTAP shall apply for renewal at least sixty (60) days prior to expiration by

submitting an application for renewal and updated documentation demonstrating continued compliance. If an applicant fails to renew on time, it shall be required to apply as a new applicant.

- e. **Registry** – Accredited DTAPs shall be published in the DICT’s official registry on its website. The DICT shall notify the public and government agencies of the accreditation status.

Section 7. Accreditation of DICT Trusted Assessment Providers for CIIs and Government Agencies. – DTAPs shall be accredited to deliver VAPT and ISMS-related services to government agencies and organizations classified as CIIs in accordance with the NCSP 2023-2028.

Section 8. Post-Assessment of Cybersecurity Providers. – The DICT, through the Cybersecurity Bureau, shall implement a Post-Audit Assessment as part of the continuous oversight and monitoring functions.

- a. **Quarterly Post-Assessment Evaluation** – The Cybersecurity Bureau shall conduct a quarterly post-audit assessment of the accredited DTAP based on the engagement conducted within each quarter. These audits shall be aligned with the suggested VAPT and ISMS methodologies, quality, timeline of deliverables, and ethical conduct during engagement.
- b. **Mandatory Client Feedback Mechanism and Requirement for Renewal of Accreditation** – All accredited cybersecurity service providers are required to submit client feedback reports from the companies/firms that they have served during the accreditation period and shall be based on the standardized evaluation criteria issued by the DICT covering technical competence, professionalism, communication clarity, and overall satisfaction. These reports shall be submitted on a quarterly basis and shall form part of the DICT evaluation of the provider’s performance.

The submission of client feedback reports shall be a mandatory requirement for the renewal of accreditation. All accredited DTAPs shall submit complete and verifiable client feedback reports for all engagements conducted within the accreditation period, following the schedule and format prescribed by the Cybersecurity Bureau. Furthermore, the consistent receipt of poor feedback ratings, particularly those involving data mishandling, unethical conduct, or repeated client dissatisfaction, shall be considered grounds for revocation of the accreditation.

Section 9. Suspension or Revocation of Accreditation. – The DICT, through its Cybersecurity Bureau, may suspend or revoke the accreditation of a DTAP after due notice and hearing for any of the following grounds:

- a. Material misrepresentation or falsification of information in the application or renewal documents;
- b. Failure to maintain the minimum personnel qualifications, certifications, or other requirements specified in this Circular;
- c. Commission of illegal or unethical acts in the course of performing assessments, such as but not limited to unauthorized exploitation of discovered vulnerabilities, extortion of clients, or any act contrary to the stated code of conduct;
- d. Violation of any provision of this Circular or of the terms of the accreditation certificate;
- e. Receipt of substantiated complaints or negative findings indicating gross negligence or malpractice by the provider in performing cybersecurity assessments;
- f. Failure to comply with the quarterly post-audit assessment requirement conducted by the Cybersecurity Bureau, which includes the submission of client feedback reports from organizations served within the accreditation period. Non-compliance, or consistent negative feedback indicating poor service quality or unethical conduct may be grounds for suspension or revocation;
- g. Non-performance and inferior quality of the accredited service provider including, but not limited to, absence of feedback from its client engagement, or substandard performance within one (1) year.

Suspension or revocation shall be without prejudice to any criminal, civil, or administrative penalties that may be imposed under applicable laws. The DICT Cybersecurity Bureau shall promulgate rules for the conduct of hearings and appeals related to accreditation decisions.

Section 10. Responsibilities of Covered Entities. — All covered agencies, instrumentalities, and entities shall:

- a. Require, as a precondition for the procurement of VAPT services, that the service provider be listed as an accredited DTAP by the DICT;
- b. Immediately report to the Cybersecurity Bureau any security incidents or irregularities associated with the conduct of assessments by a DTAP;
- c. Cooperate with the DICT in any audits or monitoring activities related to the engagement of DTAPs; and
- d. Adhere to any additional guidelines or compliance requirements that the DICT may prescribe to implement this Circular.

Section 11. Penalties. — Any individual or entity found to have violated the provisions of this Circular shall be referred to the appropriate government agency, such as the Cybercrime Investigation and Coordinating Center (CICC), the National Privacy Commission (NPC), or other relevant government authorities for proper investigation and possible administrative, civil, or criminal action in accordance with existing laws, rules and regulations.

Section 12. Separability. — If any provision of this Circular is declared invalid or unconstitutional, the other provisions not affected thereby shall remain valid and subsisting.

Section 13. Repealing Clause. — All issuances, orders, rules, and regulations that are inconsistent with the provisions of this Circular are hereby repealed or modified accordingly.

Section 14. Transitory Provisions. — To ensure an orderly shift from the DICT's prior recognition program for cybersecurity assessment providers to the accreditation of DICT Trusted Assessment Providers (DTAPs) under this Circular, the following shall apply:

a. Discontinuance of Prior Recognition Program

Upon the effectivity of this Circular, the DICT's prior program for the recognition of cybersecurity assessment providers shall be discontinued immediately. No new recognitions shall be accepted, processed, or issued thereunder.

b. Transition Period

A transition period of ninety (90) days from the effectivity of this Circular (the "Transition Period") is hereby established.

After the Transition Period, only DTAPs under this Circular may render VAPT and ISMS assessment services to entities covered under Section 3.

c. Pending Applications Under the Prior Recognition Program

All applications pending under the prior recognition program as of the effectivity date shall be converted, without need of re-filing, into applications for DTAP accreditation under this Circular, subject to submission of any additional documentary and substantive requirements within thirty (30) calendar days from the effectivity of this circular.

Failure to submit the required documents within the prescribed period shall be a ground to deny the converted application without prejudice to filing a new application.

d. Provisional Accreditation to Prevent Service Disruption

To avoid material service disruption to CIIs and covered government entities, the Cybersecurity Bureau may, for meritorious cases and subject to risk-mitigating conditions, issue a non-extendible provisional accreditation valid for a period not exceeding one hundred-eighty (180) days from the end of the transition period to applicants that have substantially complied with Section 4 but require additional time to complete entity-level certifications under Section 4(f).

Provisional accreditation shall specify the scope of services allowed, mandatory safeguards, reporting duties, and a timetable for full compliance. Failure to achieve full compliance within the provisional period shall automatically result in the lapse of provisional accreditation.

Section 15. Effectivity Clause. — This Circular shall take effect fifteen (15) calendar days after its publication in the Official Gazette or any newspaper of general circulation and upon filing with the Office of the National Administrative Register (ONAR) of the University of the Philippines Law Center.

Let copies of this Circular be posted and published on the official DICT website and bulletin boards.

 Digitally signed
by Aguda Henry
Rhoel Ratuira

HENRY R. AGUDA

Secretary

Copy furnished:

All concerned.

ANNEX A

List of Certifications for Personnel of Vulnerability Assessment and Penetration Testing (VAPT) and Information Security Management System (ISMS) Assessment Services

1. **VAPT Assessment Services** – Applicant's personnel assigned to conduct VAPT-related services shall hold the following minimum qualifications, as applicable to their experience and position in their respective field:

- a. **Senior Engineer / Specialist** shall hold at least two (2) of the following cybersecurity certifications from a reputable international credentialing bodies such as, but not limited to:
 - i. Practical Network Penetration Tester (PNPT);
 - ii. Global Information Assurance Certification Penetration Tester (GPEN);
 - iii. Offensive Security Web Assessor (OSWA);
 - iv. Global Information Assurance Certification Web Application Penetration Tester (GWAPT);
 - v. EC-Council Certified Penetration Testing Professional (CPENT);
 - vi. EC-Council Licensed Penetration Tester (LPT);
 - vii. OffSec Experienced Pentester (OSEP);
 - viii. Offensive Security Certified Professional (OSCP);
 - ix. Altered Security's Certified Red Team Professional (CRTP);
 - x. Global Information Assurance Certification Exploit Researcher; or
 - xi. Advanced Penetration Tester (GXPNT).

The senior engineer / specialist shall also have a minimum of eight (8) years experience as a cybersecurity engineer and/or penetration tester.

- b. **Junior Analyst / Associate Tester / Engineer** shall hold at least one (1) of the following cybersecurity certifications from reputable international credentialing bodies such as, but not limited to:
 - i. eLearnSecurity Junior Penetration Tester (eJPT), *CompTIA PenTest+*;
 - ii. EC-Council Certified Ethical Hacker (CEH); or
 - iii. eLearnSecurity Certified Professional Penetration Tester v2 (eCPPTv2).

2. **ISMS Assessment Services** – Applicant's personnel designated to perform ISMS assessments shall hold at least one (1) of the following professional certifications :
 - a. ISO/IEC 27001 Lead Auditor or Lead Implementer;
 - b. Certified Information Security Manager (CISM) issued by the *Information Systems Audit and Control Association (ISACA)*;
 - c. Certified Information Systems Auditor (CISA) issued by ISACA;
 - d. Certified Information Systems Security Professional (CISSP) issued by the *International Information System Security Certification Consortium (ISC²)*; or
 - e. any other equivalent Information System Security certification issued by a reputable international credentialing body.

Date: November 28, 2025